## Amenazas: Interrupción, Intercepción, Modificación y Fabricación.

Los tres elementos principales a proteger en cualquier sistema informático son el software, el hardware y los datos. Contra cualquiera de los tres elementos dichos anteriormente (pero principalmente sobre los datos) se pueden realizar multitud de ataques o, dicho de otra forma, están expuestos a diferentes amenazas. Generalmente, la taxonomía más elemental de estas amenazas las divide en cuatro grandes grupos: interrupción, interceptación, modificación y fabricación. Un ataque se clasifica como interrupción si hace que un objeto del sistema se pierda, quede inutilizable o no disponible. Se tratará de una interceptación si un elemento no autorizado consigue un acceso a un determinado objeto del sistema, y de una modificación si además de conseguir el acceso consigue modificar el objeto; algunos autores [Olovsson, 1992) consideran un caso especial de la modificación: la destrucción, entendiéndola como una modificación que inutiliza al objeto afectado. Por último, se dice que un ataque es una fabricación si se trata de una modificación destinada a conseguir un objeto similar al atacado de forma que sea difícil distinguir entre el objeto original y el "fabricado". En la figura 1.3 se muestran estos tipos de ataque de una forma gráfica.

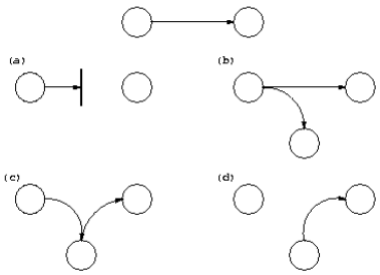



**Figura 1.3:** Flujo normal de información entre emisor y receptor y posibles amenazas: (a) interrupción, (b) interceptación, (c) modificación y (d) fabricación **[Gallo, 2001].**

## Ataques: DoS, Sniffing, Man in the middle, Spoofing, Pharming.

### Ataque *man-in-the-middle o JANUS*

En criptografía, un **ataque *man-in-the-middle o JANUS*** (**MitM** o *intermediario*, en español) es un ataque en el que el enemigo adquiere la capacidad de leer, insertar y modificar a voluntad, los mensajes entre dos partes sin que ninguna de ellas conozca que el enlace entre ellos ha sido violado. El atacante debe ser capaz de observar e interceptar mensajes entre las dos víctimas. El ataque MitM es particularmente significativo en el protocolo original de intercambio de claves de Diffie-Hellman, cuando éste se emplea sin autenticación.

### Posibles subataques

El ataque MitM puede incluir algunos de los siguientes subataques:

- Intercepción de la comunicación (*eavesdropping*), incluyendo análisis del tráfico y posiblemente un ataque a partir de textos planos (*plaintext*) conocidos.
- Ataques a partir de textos cifrados escogidos, en función de lo que el receptor haga con el mensaje descifrado.
- Ataques de sustitución.
- Ataques de repetición.
- Ataque por denegación de servicio (*denial of service*). El atacante podría, por ejemplo, bloquear las comunicaciones antes de atacar una de las partes. La defensa en ese caso pasa por el envío periódico de mensajes de *status* autenticados.

MitM se emplea típicamente para referirse a manipulaciones activas de los mensajes, más que para denotar intercepción pasiva de la comunicación.

## Defensas contra el ataque

La posibilidad de un ataque de intermediario sigue siendo un problema potencial de seguridad serio, incluso para muchos criptosistemas basados en clave pública. Existen varios tipos de defensa contra estos ataques MitM que emplean técnicas de autenticación basadas en:

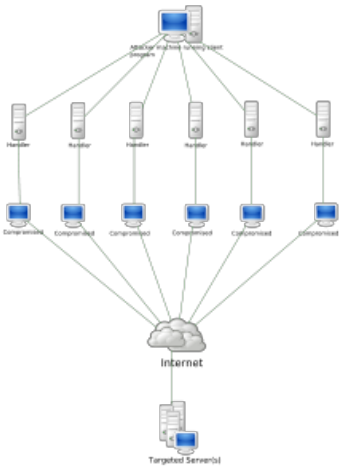
- Claves públicas
- Autenticación mutua fuerte
- Claves secretas (secretos con alta entropía)
- Passwords (secretos con baja entropía)
- Otros criterios, como el reconocimiento de voz u otras características biométricas

La integridad de las claves públicas debe asegurarse de alguna manera, pero éstas no exigen ser secretas, mientras que los passwords y las claves de secreto compartido tienen el requerimiento adicional de la confidencialidad. Las claves públicas pueden ser verificadas por una autoridad de certificación (CA), cuya clave pública sea distribuida a través de un canal seguro (por ejemplo, integrada en el navegador web o en la instalación del sistema operativo).

## *DoS*- Ataque de denegación de servicio

En seguridad informática, un **ataque de denegación de servicio**, también llamado ataque **DoS** (de las siglas en inglés ***D**enial **o**f **S**ervice*), es un ataque a un sistema de computadoras o red que causa que un servicio o recurso sea inaccesible a los usuarios legítimos. Normalmente provoca la pérdida de la conectividad de la red por el consumo del ancho de banda de la red de la víctima o sobrecarga de los recursos computacionales del sistema de la víctima.

Se genera mediante la saturación de los puertos con flujo de información, haciendo que el servidor se sobrecargue y no pueda seguir prestando servicios, por eso se le denomina "denegación", pues hace que el servidor no dé abasto a la cantidad de solicitudes. Esta técnica es usada por los llamados Crackers para dejar fuera de servicio a servidores objetivo.




Una ampliación del ataque Dos es el llamado **ataque distribuido de denegación de servicio**, también llamado ataque **DDoS** (de las siglas en inglés***D**istributed **D**enial **o**f **S**ervice*) el cual lleva a cabo generando un gran flujo de información desde varios puntos de conexión.

La forma más común de realizar un DDoS es a través de una botnet, siendo esta técnica el ciberataque más usual y eficaz por su sencillez tecnológica.

En ocasiones, esta herramienta ha sido utilizada como un buen método para comprobar la capacidad de tráfico que un ordenador puede soportar sin volverse inestable y afectar a los servicios que presta. Un administrador de redes puede así conocer la capacidad real de cada máquina

## Sniffing -*analizador de paquetes*

En informática, un **analizador de paquetes** es un programa de captura de las tramas de una red de computadoras.

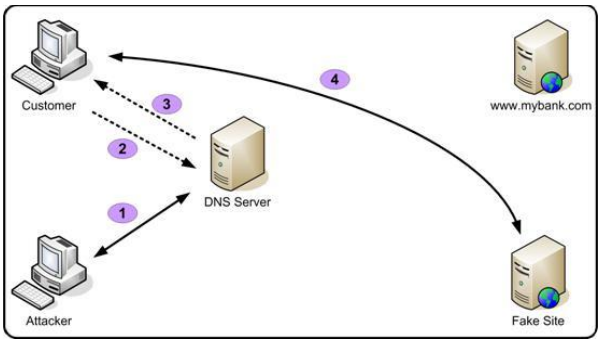
Es algo común que, por topología de red y necesidad material, el medio de transmisión (cable coaxial, cable de par trenzado, fibra óptica, etc.) sea compartido por varias computadoras y dispositivos de red, lo que hace posible que un ordenador capture las tramas de información no destinadas a él. Para conseguir esto el analizador pone la tarjeta de red en un estado conocido como "modo promiscuo" en el cual en la capa de enlace de datos no son descartadas las tramas no destinadas a la dirección MAC de la tarjeta; de esta manera se puede capturar (*sniff*, "olfatear") todo el tráfico que viaja por la red.

Los analizadores de paquetes tienen diversos usos, como monitorear redes para detectar y analizar fallos, o para realizar ingeniería inversa en protocolos de red. También es habitual su uso para fines maliciosos, como robar contraseñas, interceptar correos electrónicos, espiar conversaciones de chat, etc.

## Spoofing

**Spoofing**, en términos de seguridad de redes hace referencia al uso de técnicas de suplantación de identidad generalmente con usos maliciosos o de investigación.

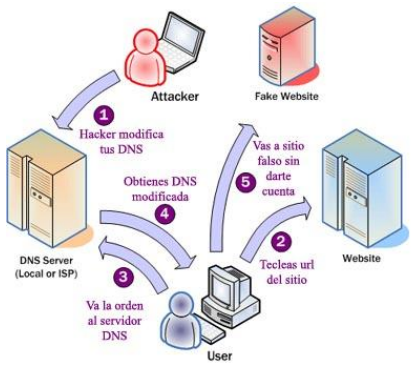
Se pueden clasificar los ataques de *spoofing*, en función de la tecnología utilizada. Entre ellos tenemos el IP spoofing (quizás el más conocido), ARP spoofing, DNS spoofing, Web spoofing o email spoofing, aunque en general se puede englobar dentro de spoofing cualquier tecnología de red susceptible de sufrir suplantaciones de identidad.




- **Tipos de Spoofing**
  - IP Spoofing
  - ARP Spoofing
  - DNS Spoofing
  - Web Spoofing
  - Mail Spoofing

## Pharming

Pharming es la explotación de una vulnerabilidad en el software de los servidores DNS (*Domain Name System*) o en el de los equipos de los propios usuarios, que permite a un atacante redirigir un nombre de dominio (*domain name*) a otra máquina distinta. De esta forma, un usuario que introduzca un determinado nombre de dominio que haya sido redirigido, accederá en su explorador de internet a la página web que el atacante haya especificado para ese nombre de dominio.




**Método de funcionamiento del pharming**

Todos los ordenadores conectados a internet tienen una dirección IP única, que consiste en 4 octetos (4 grupos de 8 dígitos binarios) de 0 a 255 separados por un punto (ej: 127.0.0.1). Estas direcciones IP son comparables a las direcciones postales de las casas, o al número de los teléfonos.

Debido a la dificultad que supondría para los usuarios tener que recordar esas direcciones IP, surgieron los Nombres de Dominio, que van asociados a las direcciones IP del mismo modo que los nombres de las personas van asociados a sus números de teléfono en una guía telefónica.

Los ataques mediante *pharming* pueden realizarse de dos formas: directamente a los servidores DNS, con lo que todos los usuarios se verían afectados, o bien atacando a ordenadores concretos, mediante la modificación del fichero "hosts" presente en cualquier equipo que funcione bajo Microsoft Windows o sistemas Unix.

La técnica de *pharming* se utiliza normalmente para realizar ataques de *phishing*, redirigiendo el nombre de dominio de una entidad de confianza a una página web, en apariencia idéntica, pero que en realidad ha sido creada por el atacante para obtener los datos privados del usuario, generalmente datos bancarios.

- **Riesgos potenciales en los servicios de red:**

**Seguridad en los dispositivos de red:**

**¿Qué se tiene que hacer?**

- Enumerar protocolos, puertos y servicios a ser permitidos o filtrados en cada interface, así como los procedimientos para su autorización.
- Describir procedimientos de seguridad y roles para interactuar con proveedores externos.

**Seguridad física**

- Designar el personal para actividades de instalación, desinstalación.
- Designar la persona para realizar actividades de mantenimiento.
- Designar la persona para realizar la conexión física.
- Definir controles de colocación y usos de la consola y los puertos de acceso.
- Definir procedimientos de recuperación ante eventualidades físicas.

***Terminales***

La seguridad en los terminales, es la seguridad que se consigue poniendo programas en los terminales como un antivirus, antimalware, antizombies etc…

***Switch***

Los puertos del switch pueden ser un punto de entrada a la red por parte de usuarios no autorizados. Para evitarlo, los switches ofrecen una función que se conoce como seguridad de puertos. La seguridad de puerto limita la cantidad de direcciones MAC válidas que se permiten por puerto. El puerto no reenvía paquetes con direcciones MAC de origen que se encuentran fuera del grupo de direcciones definidas.

Existen tres maneras de configurar la seguridad de puerto.

***Estática***

Las direcciones MAC se configuran manualmente con el comando de configuración de interfaz switchport port-security mac-address. Las direcciones MAC estáticas se almacenan en la tabla de direcciones y se agregan a la configuración en ejecución.

***Dinámica***

Las direcciones MAC se aprenden de manera dinámica y se almacenan en la tabla de direcciones. Se puede controlar la cantidad de direcciones que se aprenden. La cantidad máxima predeterminada de direcciones MAC que se aprenden por puerto es una. Las direcciones que se aprenden se borran de la tabla si el puerto se desconecta o si el switch se reinicia.

***Sin modificación***

Similar a dinámica excepto que las direcciones también se guardan en la configuración en ejecución.

La seguridad del puerto se deshabilita de manera predeterminada. Si se habilita la seguridad del puerto una violación hace que el puerto se desconecte. Por ejemplo, si se habilita la seguridad de puerto dinámica y la cantidad máxima de direcciones MAC por puerto es uno, la primera dirección que se aprende se transforma en la dirección segura. Si otra estación de trabajo intenta acceder al puerto con una dirección MAC diferente se produce una infracción de seguridad.

***Router***

El mínimo es cambiar la contraseña que viene por defecto. Tendremos que generar una password fuerte que no sea fácilmente identificable por posibles atacantes. La segunda opción es tapar el agujero que puede suponer tener determinados puertos abiertos, cuestión que podemos evaluar con cualquier escaneado de puertos.

Por último una opción sencilla y que no evita ataques pero si curiosos merodeando por nuestro espectro es ocultar nuestra red WiFi. Además de las medidas de protección que hayamos tomado para proteger el acceso, mantener la red oculta a la detección automática nos evitará que más de un curioso se interese por nuestra red. Son medidas sencillas, que con un par de manuales de nuestro modelo de router podemos poner en práctica y tener un poco más de seguridad en nuestra red.

**Seguridad de configuración estática**

- Designar la(s) persona(s) que accede(n) al router vía consola o en forma remota.
- Designar la persona con privilegios de administración.
- Definir procedimientos para realizar cambios a la configuración.
- Definir políticas de password de usuario y administrador.
- Definir protocolos, procedimientos y redes para acceso remoto.
- Definir plan de recuperación que incluya responsabilidades individuales ante incidentes.
- Definir políticas de revisión de bitácoras.
- Definir procedimientos y limitaciones del monitoreo remoto (SNMP).
- Definir directrices para la detección de ataques directos.
- Definir políticas de administración e intercambio de información (Protocolos de ruteo, RADIUS, SNMP, TACAS+, NTP).
- Definir políticas de intercambio de llaves de encriptación.
- Seguridad de configuración dinámica
- Identificar los servicios de configuración dinámica del router, y las redes permitidas para acceder dichos servicios
- Identificar los protocolos de ruteo a utilizar, y sus esquemas de seguridad que proveen.

**Seguridad de configuración dinámica**

- Designar mecanismos y políticas de actualización del reloj (manual o por NTP).
- Identificar los algoritmos criptográficos autorizados para levantar VPN's.

***WIFI***

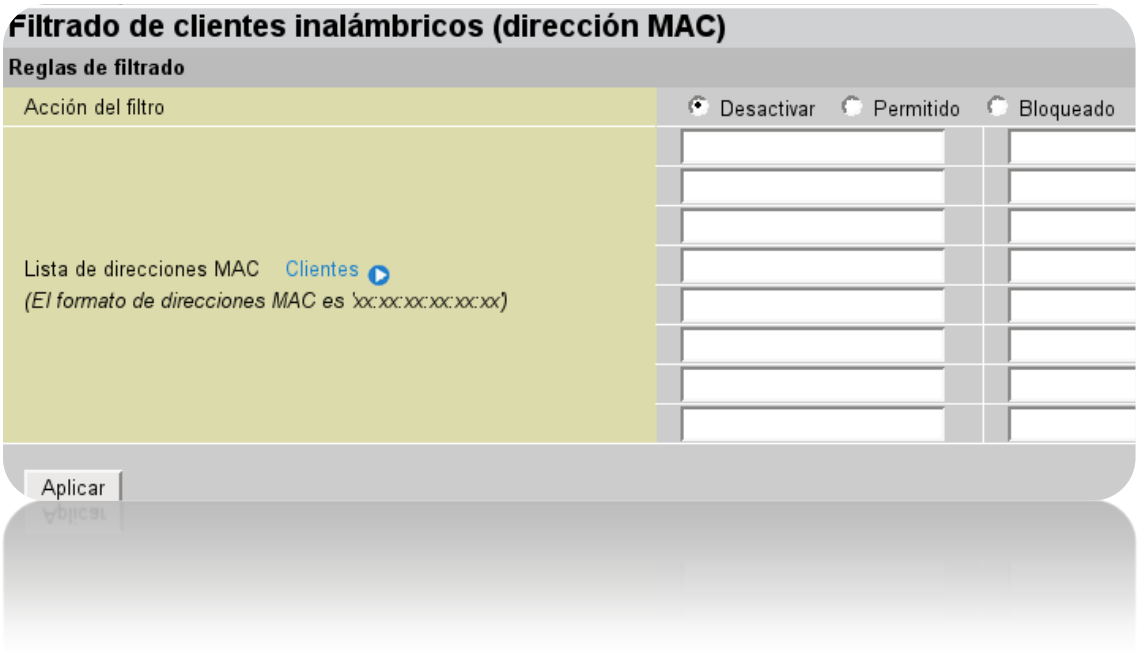
Si seleccionamos la opción wireless de nuestro router para configurarlo con seguridad nos aparecerán una serie de opciones comunes:

- **Esconder tu red**: Se trata de marcar una opción en la configuración para que cuando se realizan búsquedas de redes para conectarte no aparezca la tuya. En realidad, es como una protección contra curiosos. Previamente nosotros le hemos dado un nombre a nuestra red, generalmente en el apartado SSID donde nos aparecerá un nombre por defecto.
- **Deshabilitar el servidor DHCP**: Generalmente cuando queremos conectarnos a una red dejamos que sea el propio router el que nos asigne automáticamente una dirección IP. Si queremos que alguien no acceda a nuestra conexión podemos desactivar esta opción y asignar manualmente nosotros las direcciones IP a los equipos.

**Filtrado de direcciones MAC**: Esta es una de las medidas más efectivas a mi entender respecto a la seguridad inalámbrica. Como hemos visto anteriormente cada tarjeta de red tiene una dirección física única en el mundo para identificarse. Podemos indicarle al router que tarjetas de red se pueden

conectar, dejando operativas las de nuestros equipos cotidianos y denegando el resto. Con esto evitamos que aunque descubran nuestra contraseña o consigan acceder a nuestra red, el router no los reconozca como autorizados al no tener la dirección MAC del equipo extraño que quiere conectarse como autorizada en su lista

A parte de todas estas precauciones nos queda por contar que tipo de **contraseñas de seguridad y cifrad**o podemos ponerle a nuestra conexión para hacer que la información viaje lo más segura posible entre nuestro equipo y el modem router que nos conecta a internet. Como en todos los temas de seguridad es importante saber que **nada es infalible** y como todos hemos oído que se introducen en ordenadores de tal o cual organización, pues claro está que si lo intentan lo más probable es que consigan entrar en nuestra red.




**Seguridad en los servicios de red por niveles:**

El modelo OSI está pensado para que cada capa opere independiente de las demás.
Esto significa que una capa puede ser comprometida sin que las demás lo noten.

## Ataque en la Capa Enlace de datos

**Mitos de la capa de enlace de datos**

- Las direcciones MAC no pueden ser falsificadas.
- Un switch no permite hacer sniffing.
- Las VLANs están completamente aisladas unas de otras.

### *Ataques basados en MAC y ARP:*

**CAM Table Overflow**

- Los switchs guardan las asociaciones MACPuerto e información de VLAN a medida que las "aprenden" en un tabla llamada tabla CAM.
- La tabla CAM de un switch tiene un tamaño fijo y finito.
- Cuando la tabla CAM no tiene espacio para almacenar más asociaciones MAC-Puerto envía a todos los puertos las tramas que tengan una dirección MAC destino no almacenado en la tabla CAM. (Actúa como un HUB para cualquier MAC que no haya aprendido)

• Se basa en el tamaño limitado de la tabla CAM.
• Para realizar el ataque sólo hace falta enviar gran número de tramas con direcciones MAC distintas (usualmente generadas al azar) a cualquier puerto del switch hasta que se llene la tabla CAM.
• Se desarrolló una herramienta para tal fin llamada macof.

Actualmente es parte del paquete Dsniff (GNU/Linux).

**Address Resolution Protocol(ARP)**

La solicitud ARP se coloca en una trama broadcast y se envía.
Todas las estaciones reciben la trama y examinan el pedido.
La estación mencionada en el pedido contesta y todas las demás estaciones procesan la misma.

### *Ataques que usan ARP Spoofing*

**Switch Port Stealing (Sniffing):**

Utilizando ARP Spoofing el atacante consigue que todas las tramas dirigidas hacia otro puerto del switch lleguen al puerto del atacante para luego re-enviarlos hacia su destinatario y de esta manera poder ver el tráfico que viaja desde el remitente hacia el destinatario (Una especie de sniffig half-duplex).

**Man in the Middle (Sniffing):**

Utilizando ARP Spoofing el atacante logra que todas las tramas que intercambian las víctimas pasen primero por su equipo (Inclusive en ambientes switcheados)

**Secuestro (Hijacking):**

Utilizando ARP Spoofing el atacante puede lograr redirigir el flujo de tramas entre dos dispositivos hacia su equipo. Así puede lograr colocarse en cualquiera de los dos extremos de la comunicación (previa deshabilitación del correspondiente dispositivo) y secuestrar la sesión.

**Denial of service (DoS):**

Utilizando ARP Spoofing el atacante puede hacer que un equipo crítico de la red tenga una dirección MAC inexistente. Con esto se logra que las tramas dirigidas a la IP de este dispositivo se pierdan.

### *Ataques basados en VLAN*

**Dinamic Trunk Protocol (DTP)**

• Automatiza la configuración de los trunk 802.1Q/ISL.
• Sincroniza el modo de trunking en los extremos.
• Hace innecesaria la intervención administrativa en ambos extremos.

**VLAN Hopping Attack**

• Un equipo puede hacerse pasar como un switch con 802.1Q/ISL y DTP, o bien se puede emplear un switch.
• El equipo se vuelve miembro de todas las VLAN.
• Requiere que el puerto este configurado con trunking automático.

**Double Tagged VLAN Hopping Attack**

• Se envian una trama 802.1Q de la VLAN de la víctima dentro de otra trama 802.1Q de nuestra VLAN.

• Los switchs realizan un solo nivel de desencapsulado.
• Solo permite tráfico en una sola dirección.
• Sólo funciona si la VLAN nativa del trunk es la misma a la que pertenece el atacante.
• Funciona aunque el puerto del atacante tenga desactivado el trunking.

**VLAN Trunking Protocol (VTP)**

• Se lo emplea para distribuir configuraciones de VLAN a través de múltiples dispositivos.
• VTP se emplea únicamente en puertos trunk.
• VTP puede causar muchos inconvenientes.
• VTP emplea autenticación considere usar MD5.
• Si un atacante logra que su puerto se convierta en trunk, puede enviar mensajes VTP como si fuera un servidor VTP sin VLANs configuradas. Cuando los demás switches reciban el mensaje eliminarán todas sus VLANs.

**¿Cómo protegerse?**

Siempre utilizar una VLAN dedicada para los puertos trunk.

• Deshabilitar los puertos no utilizados y colocarlos en una VLAN no utilizada.
• No utilizar la VLAN 1 para nada.
• Colocar todos los puertos de los usuarios como non-trunking (Deshabilitar DTP)

***Ataques basados en STP***

• El atacante envía mensajes BPDU forzando recálculos STP.
• El atacante envía mensajes BPDU para convertirse en root.
• El atacante se convierte en root con lo cual puede ver tramas que no debería (esto permite ataques MiM, DoS, etc)
• Hace falta que el atacante esté conectado a dos switches simultáneamente.
El atacante envía mensajes BPDU anunciándose como bridge con prioridad 0.
• El atacante se vuelve root.
• Si se lo combina con MAC flooding este ataque puede permitir capturar más tramas.

**¿Cómo protegerse?**

- No deshabilitar STP (introducir un loop puede convertirse en una forma de ataque).
- Habilitar BPDU Guard: (Dentro del modo configuración global)

  **Switch(config)# spanning-tree portfast bpduguard default**

  (Dentro del modo configuración de interface del puerto a configurar)

  **Switch(config-if)# spanning-tree bpduguard enable**
  o
  **Switch(config-if)# spanning-tree portfast**

- Habilitar Root Guard:

  (Dentro del modo configuración de interface del puerto a configurar)
  **Switch(config-if)# spanning-tree guard root**

**Ataque en la Capa Red (ip)**
Sin medidas de seguridad, tanto las redes públicas como las privadas están expuestas a la observación y el acceso no autorizados. Los ataques internos pueden ser la consecuencia de una seguridad de intranet mínima o incluso inexistente. Los riesgos provenientes del exterior de la red privada se originan en las conexiones a Internet y a extranets. Los controles de acceso de usuarios basados en contraseñas no protegen por sí solos los datos transmitidos a través de una red.

**Tipos comunes de ataques a redes**
Si no se toman medidas de seguridad ni se aplican controles, los datos pueden ser objeto de un ataque. Algunos ataques son pasivos, en el sentido de que sólo se observa la información. Otros ataques son activos y se modifica la información con intención de dañar o destruir los datos o la propia red. Cuando no se tiene un plan de seguridad, las redes y los datos son vulnerables a todos los tipos de ataques siguientes.

**Espionaje**
En general, la mayoría de las comunicaciones por red tienen lugar en formato de texto simple (sin cifrar), lo que permite al atacante que haya logrado el acceso a las rutas de datos de una red observar e interpretar (leer) el tráfico. El espionaje de las comunicaciones por parte de un atacante se conoce como husmear. La capacidad de los espías para observar la red suele ser el mayor problema de seguridad que afrontan los administradores de las compañías. Sin unos servicios de cifrado eficaces basados en criptografía, mientras los datos atraviesan la red pueden ser observados por terceros.

**Modificación de datos**
Cuando un atacante ha leído los datos, a menudo el siguiente paso lógico consiste en modificarlos. Un atacante puede modificar los datos de un paquete sin que el remitente ni el receptor lo adviertan. Incluso cuando no se requiera confidencialidad en todas las comunicaciones, no se desea que los mensajes se modifiquen en su camino. Por ejemplo, si intercambia solicitudes de compra, no desea que se modifique la información relativa a los artículos, los importes ni la facturación.

**Suplantación de identidad (direcciones IP ficticias)**
La mayoría de las redes y sistemas operativos utilizan la dirección IP para identificar un equipo como válido en una red. En algunos casos, es posible utilizar una dirección IP falsa. Esta práctica se conoce como suplantación. Un atacante podría utilizar programas especiales para construir paquetes IP que parezcan provenir de direcciones válidas dentro de la intranet de una organización.

Una vez obtenido el acceso a la red con una dirección IP válida, el atacante podrá modificar, desviar o eliminar datos. También podrá realizar ataques de otros tipos, como se describe en las secciones siguientes.

**Ataques basados en contraseñas**
Un procedimiento común en la mayoría de los sistemas operativos y planes de seguridad de redes es el control de acceso basado en contraseñas. El acceso tanto a un equipo como a los recursos de la red está determinado por un nombre de usuario y una contraseña.

Históricamente, muchas versiones de componentes de sistemas operativos no siempre protegían la información de identidad cuando ésta pasaba por la red para su validación. Ello podría permitir a un espía detectar un nombre de usuario y una contraseña válidos, y utilizarlos para lograr acceso a la red haciéndose pasar por un usuario autorizado.

Cuando un atacante encuentra una cuenta de usuario válida y la utiliza para el acceso, obtendrá los mismos derechos que el usuario real. Por ejemplo, si el usuario tiene derechos administrativos, el atacante puede crear cuentas adicionales para tener acceso posteriormente.

Una vez obtenido el acceso a una red con una cuenta válida, el atacante puede hacer lo siguiente:

- Obtener listas de nombres de usuarios y equipos válidos e información de la red.
- Modificar las configuraciones de los servidores y de la red, incluidos los controles de acceso y las tablas de enrutamiento.
- Modificar, desviar o eliminar datos.

**Ataque de rechazo de servicio**

A diferencia de un ataque basado en contraseñas, el ataque de rechazo de servicio impide el uso normal de un equipo o de una red por parte de los usuarios autorizados.

Una vez obtenido el acceso a una red, el atacante puede hacer lo siguiente:

- Distraer al personal de sistemas de información para que no detecte inmediatamente la intrusión. Esto da al atacante la oportunidad de llevar a cabo ataques adicionales.
- Enviar datos no válidos a aplicaciones o servicios de red para provocar su cierre o su funcionamiento de forma anormal.
- Generar tráfico masivamente hasta provocar el colapso de un equipo o de toda la red.
- Bloquear el tráfico, lo que hace perder el acceso a los recursos de la red por parte de los usuarios autorizados.

**Ataque por usuario interpuesto**

Como su nombre indica, un ataque por usuario interpuesto se produce cuando alguien situado entre dos usuarios que se están comunicando observa activamente, captura y controla la comunicación sin que los usuarios lo adviertan. Por ejemplo, un atacante puede negociar claves de cifrado con ambos usuarios. A continuación, cada usuario enviará datos cifrados al atacante, quien podrá descifrarlos. Cuando los equipos se comunican en niveles bajos de la capa de red, quizás no puedan determinar con qué equipos están intercambiando datos.

**Ataque de clave comprometida**

Una clave es un código o un número secreto necesario para cifrar, descifrar o validar información protegida. Averiguar una clave es un proceso difícil y que requiere grandes recursos por parte del atacante, pero no deja de ser posible. Cuando un atacante averigua una clave, ésta se denomina clave comprometida.

El atacante puede utilizar la clave comprometida para obtener acceso a una comunicación protegida sin que el remitente ni el receptor lo perciban. La clave comprometida permite al atacante descifrar o modificar los datos. El atacante también puede intentar utilizar la clave comprometida para calcular otras claves que podrían suponer el acceso a otras comunicaciones protegidas.

**Ataque de husmeador**

Un husmeador es una aplicación o dispositivo que puede leer, supervisar y capturar intercambios de datos y paquetes en la red. Si los paquetes no están cifrados, el husmeador proporciona una vista completa de los datos contenidos en el paquete. Incluso los paquetes encapsulados (enviados por un túnel) se pueden abrir y leer si no están cifrados.

El husmeador permite al atacante hacer lo siguiente:

- Analizar una red y lograr acceso a la información, y eventualmente hacer que la red deje de responder o que resulte dañada.
- Leer comunicaciones privadas.

**Ataque en la Capa de aplicación**

Los ataques en la capa de aplicación se dirigen a los servidores de aplicaciones e intentan provocar errores en su sistema operativo o en sus aplicaciones. De este modo el atacante puede llegar a eludir los controles de acceso normales. El atacante aprovecha esta situación para obtener el control de una aplicación, sistema o red, con lo que podrá hacer lo siguiente:

- Leer, agregar, eliminar o modificar datos o un sistema operativo.
- Introducir un virus que utilice los equipos y las aplicaciones de software para copiarse por toda la red.
- Introducir un programa husmeador que analice la red y obtenga información que pueda utilizarse para hacer que la red deje de responder o que resulte dañada.
- Cerrar aplicaciones de datos o sistemas operativos de forma anormal.
- Deshabilitar otros controles de seguridad para posibilitar futuros ataques

**Ataque en la Capa Transporte (TCP-UDP)**

**SSL** (Secure Socket Layer) es un protocolo criptográfico de la capa de aplicación
Proporciona autenticación, integridad y confidencialidad.
No proporciona "No repudio" Utiliza TCP Transparente para las capas superiores (aplicaciones).
Es el protocolo más utilizado en Internet para proporcionar servicios de seguridad
Utiliza criptografía simétrica y asimétrica desarrollado por Netscape hasta la versión 3.0
En el año 1996, en plena Guerra de Navegadores con Microsoft SSLv3.0 sirve de base al IETF para TLS Transport Layer Security, RFC 2246 (actualizado en la RFC 3546)

**Problemas de seguridad**

Restricción en la longitud de las claves utilizadas

**Caracteristicas**

- Fácil de utilizar e implementado en muchas aplicaciones
- Solo se aplica extremo a extremo
- Otras opciones implementadas por las aplicaciones
- Nivel de red seguro (IPSEC)

***Distintas fases de trasporte***

**Fases en SSL**

- Establecimiento de sesión
- Autenticación
- Negociación de los parámetros de cifrado que se utilizarán posteriormente
- Generar las claves
- Transferencia de Datos
- Proporcionando integridad y confidencialidad

**Fase de Negociación (Handshake)**

- Se negocian los algoritmos
- Algoritmo de cifrado simétrico y asimétrico
- Método de intercambio de claves

**Funciones resumen**

- Autenticación del servidor (obligatoria)
- Opcionalmente se autentica al cliente

**ClientKeyExchange**

- Envía cifrado el secreto premaestro calculado por el cliente
- Es la semilla de los algoritmos criptográficos que se utilizarán después
- Se cifra con la clave pública del servidor
- En este punto tenía lugar la debilidad de SSLv2, valores que deberían ser aleatorios no lo eran realmente

## • Monitorización del tráfico en redes: Herramientas

El monitoreo es saber la disponibilidad de la maquina, tiempos de respuesta por medio del ping. Saber que servicios de red se encuentran habilitados, si están en funcionamiento o han dejado de funcionar y ver los paquetes que se envían y reciben con información. Se usan unas herramientas para realizar el monitoreo.

Los administradores de red pueden utilizar estas estadísticas para realizar tareas rutinarias de solución de problemas, como encontrar un servidor que no funciona o que está recibiendo un número desproporcionado de solicitudes de trabajo.

Estas herramientas muestran los tipos siguientes de información:

- La dirección de origen del equipo que envía una trama a la red. (Esta dirección es un número hexadecimal único (o en base 16) que identifica ese equipo en la red.)
- La dirección de destino del equipo que recibió la trama.
- Los protocolos utilizados para enviar la trama.
- Los datos o una parte del mensaje que se envía.

### *Monitorizacion en Linux*

**Etherape** (etherape.sourceforge.net, *paquete etherape*): monitoriza gráficamente la actividad de toda la red (debe ejecutarse como *root*).




**WireShark** (antes **Ethereal**, *paquete wireshark*): monitoriza el tráfico de red (ejecutarlo como *root*).